

PASSIVE ASSESSMENT

API Security Findings Report

Northwind Payments — a fictional estate. Every figure below was exported from a real gateway run, not written by hand.

What we found

3CRITICAL
FINDINGS**139**CONFIRMED
DATA LEAKS**28**APIS
DISCOVERED**19**NOT IN YOUR
API SPEC

AEGIS ran in front of the API in passive mode: it inspected and recorded, and blocked nothing. In that window it discovered **28 live endpoints**, of which **8 enforce no authentication, rate limiting or firewall at all**. Two of them return customer payment-card and email data to callers presenting no credential whatsoever.

Separately, the gateway observed **139 confirmed cases** of an authenticated caller reading records it does not own — not inferred from volume, but confirmed by comparing the owner id in each response body against the caller's verified identity. This is the class of flaw a signature firewall cannot detect, because the requests are syntactically perfect.

Critical findings

Sensitive data on an endpoint that does not require authentication

WARNING • API3:2023

`GET /api/partner/v1/customers/{id}` risk 75

endpoint returned PCI/PII (credit_card, email) on 45 response(s) and authentication is not enforced by its configuration

Sensitive data exposed to unauthenticated callers

CRITICAL · API3:2023

GET /api/v1/customers/{id} risk 75

endpoint returned PCI/PII (credit_card, email) on 61 response(s) while 61 request(s) arrived without authentication

Sensitive data exposed to unauthenticated callers

CRITICAL · API3:2023

GET /api/v1/customers/{id}/cards risk 75

endpoint returned PCI (credit_card) on 18 response(s) while 18 request(s) arrived without authentication

Sensitive data exposed to unauthenticated callers

CRITICAL · API3:2023

GET /internal/reports/export risk 75

endpoint returned PCI/PII (credit_card, email) on 13 response(s) while 13 request(s) arrived without authentication

Broken object level authorization — confirmed

CRITICAL · API1:2023

GET /api/v1/invoices/{id} 45 objects read by one caller that does not own them (94 further detections elsewhere)

consumer 'analytics-batch@northwind.example' GET object '19' (/api/v1/invoices/{id}) owned by 1 other consumer(s) and never accessed by it — possible IDOR (BOLA, heuristic)

Object enumeration by a single consumer

CRITICAL · API1:2023

consumer 'analytics-batch@northwind.example' accessed 44 distinct object IDs on 'GET /api/v1/orders/{id}' (hard ceiling 25)

Privileged endpoints reachable without the role

CRITICAL · API5:2023

18 calls to the admin surface by a consumer lacking the required role

consumer 'support-tools@northwind.example' called privileged path '/api/v1/admin' holding none of the required roles admin

Endpoints your API spec does not mention

The OpenAPI document shipped alongside this API describes part of it. AEGIS compared that document against what actually served traffic and found **19 live endpoints absent from it**. Undocumented surface is not a vulnerability by itself, but it is the surface nobody reviews, rate-limits or threat-models — OWASP tracks it as API9 for that reason.

ENDPOINT	ISSUE
GET /api/partner/v1/customers/{id}	not in the spec
GET /api/v1/customers/{id}/cards	not in the spec
GET /internal/reports/export	not in the spec
GET /api/partner/v1/settlements	not in the spec
GET /internal/jobs/status	not in the spec
GET /internal/metrics	not in the spec
POST /api/v1/products	method not documented
POST /api/v1/refunds	not in the spec
GET /api/v1/refunds/{id}	not in the spec
GET /api/v1/shipments/{id}	not in the spec
GET /api/v1/subscriptions/{id}	not in the spec
GET /api/v1/webhooks	not in the spec
GET /api/v2/orders/{id}	not in the spec
GET /api/v1/admin/refunds/approve	not in the spec

5 further undocumented endpoints omitted for length.

API inventory and posture

Every endpoint below was discovered from traffic — nothing was declared in advance.

Unprotected means none of authentication, rate limiting or firewall applies to it.

One caveat stated rather than hidden: this assessment ran in passive mode, so AEGIS enforced nothing while it watched. The *partial* and *protected* labels therefore describe what was active during the assessment, not the ceiling of what the estate could enforce.

Unprotected is unaffected — an endpoint with no authentication has none either way, which is why the summary leads with that number.

ENDPOINT	POSTURE	REQ	ANON	PII	RESPONSES	RISK
GET /api/partner/v1/customers/{id}	UNPROTECTED	45	0	45		75
GET /api/v1/customers/{id}	UNPROTECTED	61	61	61		75

GET /api/v1/customers/{id}/cards	UNPROTECTED	18	18	18	75
GET /internal/reports/export	UNPROTECTED	13	13	13	75
GET /api/partner/v1/settlements	UNPROTECTED	10	0	0	50
GET /health	UNPROTECTED	126	126	0	50
GET /internal/jobs/status	UNPROTECTED	20	20	0	50
GET /internal/metrics	UNPROTECTED	20	20	0	50
GET /api/v1/products	PARTIAL	438	224	0	35
POST /api/v1/products	PARTIAL	16	16	0	35
GET /api/v1/products/{id}	PARTIAL	290	118	0	35
GET /api/v1/invoices	PARTIAL	116	0	0	25
GET /api/v1/invoices/{id}	PARTIAL	174	0	0	25
POST /api/v1/refunds	PARTIAL	45	0	0	25

Highest-risk 14 of 28 discovered endpoints shown.

Who is calling what

Consumer identity is taken from the verified JWT where one is present, and falls back to source address where none is.

CONSUMER	IDENTIFIED BY	REQUESTS	ENDPOINTS
127.0.0.1	source address (no credential)	616	9
analytics-batch@northwind.example	verified token	236	16
partner-integration@acme-partner.example	verified token	223	18
web-checkout@northwind.example	verified token	206	16
support-tools@northwind.example	verified token	205	19
legacy-importer@northwind.example	verified token	195	16
marketing-sync@northwind.example	verified token	195	16
billing-worker@northwind.example	verified token	193	16

ops-console@northwind.example	verified token	193	16
mobile-app@northwind.example	verified token	191	16

Regulatory mapping

The findings above map onto 10 controls across OWASP API Top 10, NIS2 and ISO/IEC 27001:2022. This is a mapping aid for an audit conversation, not a certification.

FRAMEWORK	CONTROL	TITLE	SEVERITY	ISSUES
OWASP API Top 10	API1:2023	Broken Object Level Authorization	CRITICAL	2
OWASP API Top 10	API3:2023	Excessive data exposure	CRITICAL	4
OWASP API Top 10	API5:2023	Broken Function Level Authorization	CRITICAL	1
OWASP API Top 10	API9:2023	Improper Inventory Management	WARNING	19
NIS2	Art. 21(2)(h)	Cryptography and encryption of data	CRITICAL	4
NIS2	Art. 21(2)(i)	Asset management	CRITICAL	22
ISO 27001:2022	A.5.34	Privacy and protection of PII	CRITICAL	4
ISO 27001:2022	A.8.2	Privileged access rights	CRITICAL	1
ISO 27001:2022	A.8.3	Information access restriction	CRITICAL	2
ISO 27001:2022	A.5.9	Inventory of information and associated assets	WARNING	19

How this report was produced

This is a sample. The API behind it — Northwind Payments — is fictional and deliberately flawed, and the customer records in it are synthetic (reserved `example.com` addresses and standard test card numbers). No real company's data appears anywhere in this document.

The findings themselves are not mocked up. A real AEGIS instance ran in front of that API, ordinary traffic was driven through it, and every number, endpoint, consumer and finding above was exported from what the gateway actually observed. The generator is committed at `demo/sample-report/` and reproduces this document end to end.

On a real engagement the same output describes your estate instead: AEGIS is deployed in passive mode, blocks nothing, and after roughly a week hands back this report. The deployment carries no production risk — no request is modified, no response is altered, and no control fails closed.